For my preliminary experiment, I wanted to see how traditional machine learning methods would compare to a more advanced model like DistilBERT when classifying cybersecurity statements from the NIST Cybersecurity Framework 2.0. I focused on three categories: Govern, Identify, and Protect. I was able to extract and validate 74 statements, using 55 to train the models and the remaining 19 to test how well they performed. My TF-IDF and Logistic Regression model ended up achieving 84.21% accuracy with a macro F1-score of 0.834, while DistilBERT only achieved 63.16% accuracy with a macro F1-score of 0.604.

I thought this was pretty interesting because I actually expected DistilBERT to perform better. Since it's a transformer-based model that can understand the context behind words rather than just looking at word patterns, I figured it would have an advantage. However, that wasn't the case here. The simpler Logistic Regression model actually performed significantly better on my test data. I'm thinking this might have something to do with the amount of data I had available. With only 55 statements to train on, DistilBERT may not have had enough examples to really learn the differences between the categories. I also noticed that both models had trouble distinguishing between certain cybersecurity statements, especially when they involved risk management, organizational processes, and other terminology that could reasonably fit into more than one category.

One thing I always try to do with these assignments is think about how the results could apply to an actual workplace. Since I work with IT governance and compliance, I could see how a model like this might eventually help organizations sort through cybersecurity documentation and identify which requirements fall under different areas of responsibility. What surprised me the most was realizing that a more advanced model doesn't necessarily mean better results. Sometimes a simpler approach can be just as effective, or even more effective, depending on the data you're working with.

Of course, I wouldn't say that Logistic Regression is automatically the better option based on this experiment alone. My dataset was relatively small, and I would want to test both models on more cybersecurity statements before making that conclusion. But so far, this has been a good reminder that choosing the right model isn't always about using the newest or most complicated technology. It's about understanding your data, evaluating the results, and figuring out what actually works for the problem you're trying to solve.